Cheatsheet AZ-305 — 14 · Seguridad: Defender, Sentinel, Key Vault, B2C y cifrado

1. Microsoft Defender for Cloud

Elemento	Qué es	Señal
CSPM (Foundational, gratis)	Secure Score, recomendaciones, inventario, cumplimiento básico	"improve security posture", "secure score"
Defender CSPM (de pago)	Attack path analysis, cloud security explorer, governance rules	"attack paths"
Defender for Servers (Plan 1/2)	Detección de amenazas en VMs (Azure, Arc), **JIT VM access**, vulnerability assessment, file integrity (P2)	"temporary RDP/SSH", "threat detection on VMs"
Defender for SQL	Vulnerability assessment + Advanced Threat Protection (inyección, anomalías)	"detect SQL injection"
Defender for Storage	Malware scanning, actividad sospechosa	"scan uploaded blobs for malware"
Defender for Containers	AKS runtime, escaneo de imágenes en ACR	"scan container images"
Defender for Key Vault / App Service / DNS / Resource Manager	Detección de amenazas por servicio	
Regulatory compliance	Dashboard por estándar (ISO 27001, PCI DSS, NIST, CIS…); basado en Azure Policy initiatives	"assess compliance against PCI DSS"
Workflow automation	Logic App ante alerta/recomendación	"automatic response"
Continuous export	Alertas/recomendaciones a Log Analytics / Event Hubs (SIEM)	"send alerts to third-party SIEM" → Event Hubs
Azure Arc	Extiende Defender a servidores on-prem / otras nubes	"hybrid servers"

- Defender **no** es un almacén de secretos ni un firewall: detecta y recomienda.
- **JIT VM access** ≠ PIM: JIT abre **puertos** temporalmente; PIM activa **roles**.

2. Microsoft Sentinel

Elemento	Qué es
Qué es	**SIEM + SOAR** nativo, sobre un Log Analytics workspace
Data connectors	Entra ID, Microsoft 365, Defender, Azure Activity, firewalls, AWS, Syslog/CEF
Analytics rules	Detecciones (KQL programadas, ML, fusion) → incidentes
Workbooks	Visualización
Hunting	Búsqueda proactiva con KQL
Playbooks	Automatización de respuesta con **Logic Apps** (SOAR)
UEBA	Análisis de comportamiento de usuarios y entidades
Señal	"SIEM", "correlate security events across sources", "automate incident response", "security orchestration"

- Sentinel vs Defender: **Defender** = postura y protección de cargas de trabajo; **Sentinel** = correlación, investigación y respuesta a escala organizacional. Se complementan (Defender es un conector de Sentinel).
- Sentinel vs Log Analytics: Sentinel **añade** detección, incidentes y automatización sobre el workspace.

3. Key Vault avanzado

Función	Detalle
Soft delete	Obligatorio (activado); retención 7-90 días; recuperar vault/objetos borrados
Purge protection	Impide borrado definitivo durante la retención, **incluso a administradores**; irreversible una vez activado; requerido para CMK de Storage/SQL/Disk Encryption
RBAC vs access policies	RBAC recomendado (Key Vault Administrator / Secrets User / Crypto User…); access policies legacy
Redes	Firewall, service endpoints, **Private Endpoint**; "Allow trusted Microsoft services"
SKU	Standard (software) · **Premium** (HSM-backed, FIPS 140-2 Level 2) · **Managed HSM** (Level 3, single-tenant, HSM pool propio) · **Dedicated HSM** (Thales, control total, sin integración PaaS)
Rotación	Rotación automática de keys por política; certificados auto-renovables con CA integrada (DigiCert, GlobalSign)
Logging	Diagnostic settings → Log Analytics para auditar uso de claves
BYOK / HYOK	Importar claves propias (BYOK); HYOK = clave nunca en la nube (solo Managed HSM / escenarios AIP)
Replicación	Automática a la región emparejada; en failover queda en solo lectura
Referencias desde App Service / Functions	@Microsoft.KeyVault(SecretUri=...) en app settings con managed identity

- "audit key use + you manage keys + always encrypted at rest" (VM disks) → **Azure Disk Encryption** con Key Vault (o SSE con CMK).
- "FIPS 140-2 Level 2" → Premium; "Level 3" → Managed HSM.

4. Microsoft Entra External ID / B2C

Concepto	Detalle
Entra B2C	Tenant separado para **clientes/consumidores**: registro, login social (Google, Facebook), federación **OIDC/SAML con IdPs de terceros**, user flows y custom policies (Identity Experience Framework)
Entra B2B	Invitar **partners** como guests al tenant corporativo; colaboración con Microsoft 365/apps
External ID	Nombre actual del paraguas (B2B + tenants externos para clientes)
B2C emite JWT	Las APIs (vía APIM validate-jwt con el metadata endpoint de la policy B2C) los validan
Señal	"customers", "social login", "third-party OIDC identity provider", "consumer-facing app" → B2C; "partner employees access our SharePoint" → B2B; "no guest accounts" → ni B2B: APIM con validación de JWT del IdP externo

5. Cifrado y protección de datos: mapa completo

Estado / necesidad	Tecnología	Detalle
Reposo, Storage	SSE (PMK / **CMK** en Key Vault)	Siempre activo; infraestructura encryption para doble capa
Reposo, discos de VM	**Azure Disk Encryption** (BitLocker/DM-Crypt, claves en tu Key Vault, auditable) · SSE con CMK · Encryption at host · Confidential disk	ADE = "you manage the keys"
Reposo, SQL	**TDE** (service-managed o CMK); Policy DINE para forzar	Archivos y backups
Columnas sensibles ocultas a DBAs	**Always Encrypted** (deterministic permite igualdad/join; randomized no)	"group and join on encrypted columns" → deterministic
Enmascarar por rol	**Dynamic Data Masking**	No cifra
Tránsito	TLS 1.2+, HTTPS only, IPsec, MACsec	"secure transfer required"
En uso	**Confidential Computing** (Confidential VMs DCasv5/ECasv5, SGX, enclaves, confidential containers)	"code being processed", "protect from cloud operator"
Claves de aplicación	Key Vault secrets + managed identity	Nunca en código
Certificados TLS	Key Vault certificates + App Service / App Gateway integración	Auto-renovación
Datos en Microsoft 365 / archivos	Microsoft Purview Information Protection (sensitivity labels, DLP)	Fuera de AZ-305 salvo mención
Inmutabilidad regulatoria	Immutable Storage (time-based Locked / legal hold)	WORM
Backups anti-ransomware	Soft delete + Resource Guard (MUA)	

6. Cumplimiento y gobernanza de seguridad

Necesidad	Solución
Evaluar contra un estándar (ISO, PCI, NIST, CIS)	Defender for Cloud **Regulatory compliance** (initiatives de Policy)
Forzar configuraciones seguras	Azure Policy (Deny/DINE): HTTPS only, TLS mínimo, sin IP pública, cifrado
Trust Center / auditorías de Microsoft	**Service Trust Portal** (SOC, ISO reports)
Residencia de datos	Elegir región/geo; Policy "allowed locations"
Separación de funciones	RBAC + PIM + Resource Guard + Purge protection
Auditoría de quién hizo qué	Activity Log (control plane) + diagnostic logs (data plane) + Entra audit logs
Retención larga de logs de seguridad (7 años)	Log Analytics archive / export a Storage inmutable
Secretos en pipelines	Key Vault + service connections con workload identity federation

7. Árbol de decisión

```
¿Qué pide?
├─ Postura, secure score, recomendaciones, JIT ........... Defender for Cloud
├─ Amenazas en VMs / SQL / Storage / contenedores ......... Defender for <servicio>
├─ SIEM, correlación multi-fuente, respuesta automatizada . Sentinel (+ playbooks Logic Apps)
├─ Cumplimiento contra un estándar ....................... Defender Regulatory compliance
├─ Secretos / claves / certificados ...................... Key Vault (Premium si HSM L2, Managed HSM si L3)
├─ Que nadie pueda borrar el vault ni las claves ......... Purge protection + soft delete
├─ Identidad de clientes / social / IdP externo .......... Entra B2C
├─ Partners con cuenta en mi tenant ...................... Entra B2B
├─ Cifrado de disco con mis claves y auditoría ........... Azure Disk Encryption
├─ Datos en uso .......................................... Confidential Computing
└─ Columna que ni el DBA pueda ver ....................... Always Encrypted
```

8. Señales → respuesta

Enunciado	Respuesta
"temporary access to management ports"	JIT VM access (Defender for Servers)
"detect SQL injection attempts"	Defender for SQL
"correlate security events from Azure, M365 and on-prem firewalls"	Sentinel

Enunciado	Respuesta
"automated response to incidents"	Sentinel playbooks (Logic Apps)
"assess against PCI DSS"	Regulatory compliance
"prevent permanent deletion of keys even by admins"	Purge protection
"FIPS 140-2 Level 2 / Level 3"	Key Vault Premium / Managed HSM
"customers sign in with Google"	Entra B2C
"join tables on encrypted columns"	Always Encrypted deterministic
"encrypt while processing"	Confidential Computing
"send Defender alerts to Splunk"	Continuous export → Event Hubs
"alerts when unauthorized login attempts on VMs"	Defender for Servers / Log Analytics security events + alert

9. Errores a evitar

1. Defender como SIEM → Sentinel.
2. Sentinel como herramienta de postura → Defender.
3. B2B cuando el enunciado dice "customers" o "no guest accounts".
4. Key Vault Standard para requisito HSM.
5. Dynamic Data Masking como cifrado.
6. Always Encrypted randomized cuando piden joins.